

PaySafe India

SOC 2 READINESS ASSESSMENT

Trust Services Criteria Scoping, System Description, Control Readiness Maturity Matrix, Detailed Readiness Gaps, Complementary User Entity Controls, Attestation-Type Decision, and Remediation Roadmap

Document Title	PaySafe India — SOC 2 Readiness Assessment v1.0
Assessment Reference	PSI-SOC2-2026-01
Subject Organization	PaySafe India (Digital Payments, UPI, BNPL Lending & Card Processing)
Trust Services Criteria Scope	Security (Common Criteria), Availability, Processing Integrity, Confidentiality, Privacy — full scope
Assessment Period (Fieldwork)	27 July 2026 – 7 August 2026
Report Issue Date	10 August 2026
Document Classification	Internal — Confidential
Report Use Restriction	This assessment, and the eventual SOC 2 report it prepares PaySafe India for, are intended for restricted use by PaySafe India management, its auditors, and specified relying parties (banking partners and enterprise customers under NDA) — not for general distribution. A SOC 2 Type I or Type II report is a restricted-use report under AT-C 105.13; it is not a general-use report of the kind a SOC 3 would be.
Version	v1.0 — Final
Lead Readiness Advisor	Ayush Joshi
Approved By	Chief Information Security Officer (CISO); Head of Compliance
Related Deliverables	ISO/IEC 27001:2022 Gap Analysis (v1.0); Third-Party Risk Management Framework (v1.0, PSI-TPRM-2026-01); PCI DSS v4.0 Gap Analysis (v1.0, PSI-PCI-2026-01); Internal Audit Report — ISMS Control Effectiveness (PSI-IA-2026-04)

Table of Contents

Table of Contents	2
1. Executive Summary	3
2. Scope and System Description	3
2.1 TSC Scoping Decision	4
2.2 System Description	4
2.3 Attestation Standard and Description Criteria Basis	6
2.4 Regulatory Context — RBI and NPCI	6
3. Control Mapping and Readiness Maturity Matrix	6
3.1 Sampling Basis	11
4. Detailed Readiness Gaps	12
Gap 1 — CC1.4: Security Awareness Training Below Completion Target	12
Gap 2 — CC4/CC7: Monitoring Exists, Detection Does Not	12
Gap 3 — CC6: Access Control Is Designed Correctly and Is Not Operating	13
Gap 4 — CC8: Change Management Is Sound, One Gate Is Missing	13
Gap 5 — CC9.2: Fourth-Party Visibility Incomplete Across the Vendor Population	13
Gap 6 — A1: Availability Testing Is a Single Data Point, Not a Trend	13
Gap 7 — C1: Unmasked PAN Retention Is the Assessment’s Headline Confidentiality Failure	14
Gap 8 — PI1: No Processing-Integrity Control Independent of the Broken Reconciliation Process	14
Gap 9 — Privacy (P1–P8): DPDP Compliance Is Not Yet a SOC 2 Privacy Control	14
5. Complementary User Entity Controls (CUECs)	14
5.1 Complementary Subservice Organization Controls (CSOCs)	15
6. Type I vs. Type II Readiness Decision	16
7. Remediation Roadmap	17
7.1 Immediate (0–30 days) — Examination-Blocking Gaps	17
7.2 Short-term (30–90 days) — Gaps That Would Produce a Qualified Opinion or Noted Exception ...	18
7.3 Medium-term (90–180 days) — Acceptable for Type I but Must Close Before a Type II Window Can Start	19

(

1. Executive Summary

Overall readiness verdict: Not Ready for Type I Today. Realistic Type I readiness by Q4 2026 (earliest November 2026); Type II observation window should not begin before that date, with report issuance no earlier than mid-to-late 2027.

That verdict is not the one PaySafe India's leadership will want to hear three weeks before booking an auditor, so it's worth stating plainly why, before walking through the matrix that supports it. Of the five Trust Services Categories, none currently sits at *Operating Effectively* across the board. Security carries two open findings — vendor MFA and deprovisioning SLA — that Internal Audit already rated Critical in PSI-IA-2026-04, with target closure dates of 15 and 31 August 2026 respectively. An auditor who samples privileged and third-party remote access during an examination window that overlaps those dates will find exactly what Internal Audit found: shared credentials with no second factor, and at least one terminated employee whose access outlived the policy SLA by 400%. That is not a design gap. That is a control that does not operate, evidenced by an internal team that already went looking and found it broken. No readiness assessment should recommend walking an auditor into a finding you already know is there.

Confidentiality fares no better, for an unrelated reason. The PCI DSS v4.0 Gap Analysis (Finding 03) documents a settlement reconciliation process that writes unmasked PAN to a file share and retains it for 180 days against a five-to-seven-day business need. PAN is squarely within PaySafe India's confidentiality commitments to its banking partners, and a control that retains sensitive data 25 times longer than its stated purpose requires is not a footnote — it is the kind of finding that gets read into the report as an exception, or worse, becomes the reason a customer's security team declines to accept the report at all.

The headline gap, if it has to be reduced to one sentence: **PaySafe India has real controls, but three of them — vendor-facing MFA, access deprovisioning, and PAN retention discipline — are currently failing in ways an auditor would sample directly into, and all three sit inside the Security and Confidentiality criteria that carry the most weight in a banking-partner's due diligence review.**

Everything else in this assessment is genuinely closer to ready than those three items suggest, which is exactly why fixing them first, rather than spreading remediation evenly across all five criteria, is the fastest credible path to an examination.

The recommended path is Type I first, not Type II, and not immediately. Section 6 develops the reasoning in full, but the short version: Type II requires proving a control operated effectively across an observation window — AICPA guidance does not mandate a minimum length, and first-report windows of three to six months are common, though six to twelve months is more persuasive to banking-partner relying parties and is the window this assessment recommends — and PaySafe India cannot start that clock honestly while two Critical findings remain open and a third confidentiality gap has no committed closure date faster than the vendor's Q1 2027 connector release cited in the PCI DSS report. Type I only requires that the control be suitably designed and in place at a point in time — a materially lower bar, and one PaySafe India can plausibly clear once the Immediate-horizon items in Section 7 close. Realistic timeline: examination-ready for Type I in Q4 2026, contingent on the remediation roadmap in Section 7 landing on schedule; Type II not before mid-2027, and only after Security and Confidentiality demonstrate operating effectiveness across a full quarter, not a point-in-time sample.

2. Scope and System Description

2.1 TSC Scoping Decision

PaySafe India is pursuing all five Trust Services Criteria — Security, Availability, Processing Integrity, Confidentiality, and Privacy — rather than the Security-only path most fintechs at this maturity stage choose. That decision is defensible, but it is not free, and it is worth being honest about both halves of that sentence before the matrix in Section 3 makes the difficulty bar concrete.

The business case for full scope is straightforward. PaySafe India's enterprise customers and banking partners are not asking "is your environment secure" in isolation; the due-diligence questionnaires this organization receives — the same ones its own TPRM Framework (Section 4) mirrors back onto its vendors — ask whether transaction processing stays available during peak settlement windows, whether a transaction amount that enters the system is the amount that settles, and whether customer PII and payment data are handled with contractual specificity rather than general assurance. ISO 27001 answers the security question reasonably well once the findings in the Internal Audit report close. It does not answer the availability, processing integrity, or privacy questions in a form a bank's own risk committee can cite. A banking partner extending a settlement relationship to PaySafe India wants Availability coverage over the UPI switch and payment processing API specifically because an outage there is the partner's problem too, not just PaySafe India's.

Full scope raises the difficulty bar in two places, and both deserve to be named rather than discovered mid-examination. Processing Integrity is the harder of the two: it requires evidence that transaction processing is complete, valid, accurate, timely, and authorized — and the same settlement reconciliation process that generates Finding 03 in the PCI DSS report is also the closest thing PaySafe India has to a processing-integrity control today, which means the confidentiality failure and the processing-integrity gap are, uncomfortably, the same broken process viewed from two angles. Privacy is the second. DPDP 2023 gives PaySafe India a real Data Fiduciary framework to point to — the TPRM Framework's Section 9 DPA requirements are a genuine head start most fintechs pursuing SOC 2 don't have — but a data-protection obligation under Indian law and a SOC 2 Privacy criterion built around the AICPA's own points of focus (notice, choice and consent, collection, use and retention, access, disclosure, quality, monitoring) are not the same document, and PaySafe India has not yet mapped one onto the other in a form an auditor would recognize as a control rather than a legal compliance program running in parallel.

None of this argues for narrowing scope. The commercial reason for pursuing all five criteria is sound, and Security-only would leave exactly the gaps — availability, transaction accuracy, data handling — that banking partners are asking about today. It argues for sequencing: closing Security and Confidentiality first (Section 7), because both have open Critical or near-Critical findings, and treating Processing Integrity and Privacy as the categories that need the most net-new control design rather than remediation of an existing control.

2.2 System Description

The following is written as it would appear in the System Description section of PaySafe India's eventual SOC 2 report — descriptive and specific enough that a prospective customer's security team could read it and understand what they are relying on.

PaySafe India operates a digital payments platform spanning UPI transaction routing, card issuing and acquiring processing, and BNPL lending, built around four systems that sit at the center of every in-scope Trust Services Criterion.

The **Payment Processing API** receives, authorizes, and routes transaction requests for both card and UPI flows. It is the system of record for whether a transaction is authorized, and its availability characteristics — not the availability of any single downstream system — are what a banking partner is actually asking about when it asks whether PaySafe India can process transactions during a settlement window. The API sits behind network security controls that segment it from PaySafe India's general corporate network, with inbound traffic restricted to the card vault and transaction database at the network layer; the PCI DSS Gap Analysis (Section 2.4) found this segmentation sound at the core, though inconsistently enforced at the perimeter where the admin portal shares a VLAN with unrelated internal tools.

The **Card Vault** is the only system in PaySafe India's estate authorized to hold primary account numbers at rest, and it does so by tokenization rather than storing PAN in the clear. This is the control that makes PaySafe India's Confidentiality posture defensible everywhere except one place: the settlement reconciliation process described below, which writes unmasked PAN outside the vault's tokenization boundary as a matter of operational necessity that was never re-architected once automated.

The **Transaction Database** retains transaction-level records referencing tokenized PAN, along with truncated PAN in legacy tables supporting dispute handling. It is the system most directly implicated in Processing Integrity, since transaction completeness and accuracy are, functionally, claims about what this database contains and when it was written to.

The **Admin Portal** is used by PaySafe India operations and support staff to view transaction records, issue refunds, and manage merchant onboarding. It renders masked PAN to the screen and holds session-level query access to the transaction database, which is why it sits inside the SOC 2 system boundary even though it does not itself store cardholder data — a system that can query sensitive data is, for evidentiary purposes, as much a part of the control environment as the data store it queries.

A fifth system, the **Settlement Reconciliation Module**, deserves separate mention because it is the single point where three of the five Trust Services Criteria intersect and currently fail together. It is a batch process connecting the transaction database to the acquiring bank's settlement files, and it depends on a third-party core-banking connector that reconciles using plaintext PAN matching — a vendor-side constraint, not a PaySafe India design choice, with a committed fix from the vendor no earlier than Q1 2027. Until that connector is replaced, this module is simultaneously PaySafe India's weakest Confidentiality control (unmasked PAN retained 180 days against a five-to-seven-day business need), its de facto Processing Integrity control (it is the mechanism that actually confirms transaction accuracy against the bank's own record), and, because DPDP 2023 treats retention beyond purpose as a data-minimization failure independent of PCI's own retention rule, a Privacy exposure as well.

Supporting the platform is a set of third-party services already established in PaySafe India's TPRM Framework: **Aegis Cloud Systems** provides the IaaS/PaaS hosting underlying the UPI switch, card-processing environment, and core-banking interface — a Critical-tier dependency whose own subcontractor flow-down agreement was, as of the TPRM Framework's issue date, still in legal review; **Aster Payment Gateway Solutions** processes card, UPI, and net-banking transactions and holds current PCI DSS v4.0.1 and SOC 2 Type II attestations of its own; **Vahini Communication Services** operates the SMS/OTP gateway used for transaction authentication; **Nirmaan KYC Solutions** performs identity verification for onboarding; **Praxis Fraud Analytics** provides real-time transaction risk scoring; and **Kavach Managed Security Services** operates 24x7 monitoring over production logs under a managed detection and response arrangement. Every one of these relationships is governed by the contractual baseline in TPRM Framework Section 8 and monitored on the tiered cadence in Section 7 of that document; where a vendor relationship is itself the constraint behind a readiness gap in this assessment

— as it is for Aegis’s subcontractor and Aster’s notification-timing language — that linkage is called out explicitly rather than treated as a purely internal control question.

The people and procedures supporting this system are anchored in the ISO/IEC 27001:2022-aligned Information Security Management System already documented in PaySafe India’s prior Gap Analysis, with the CISO holding overall accountability, the Head of IT Security owning access and monitoring controls operationally, and the Third-Party Risk Manager owning the vendor relationships named above. That governance structure is a genuine asset heading into a SOC 2 examination — it means PaySafe India is not building a control environment from nothing, only proving that an existing one operates as designed, which is a different and easier problem than the one most first-time SOC 2 candidates face.

2.3 Attestation Standard and Description Criteria Basis

This assessment prepares PaySafe India for an examination performed under AICPA SSAE No. 18, specifically the concepts in AT-C Section 105 (concepts common to all attestation engagements) and the examination-level requirements in AT-C Section 205, applied through the AICPA’s SOC 2 guidance. The eventual report’s System Description (Section 2.2 above, drafted here in the form it would take in that report) will need to satisfy the AICPA’s Description Criteria for a Description of a Service Organization’s System in a SOC 2 Report — specifically, a statement of the types of services provided, the principal service commitments and system requirements, the components of the system (infrastructure, software, people, data, and procedures, all addressed above), the system’s boundaries, and a description of any significant changes to the system during the period under examination. Section 2.2 has not yet been benchmarked line-by-line against those criteria; that benchmarking is a discrete pre-examination task and is added to the remediation roadmap (Section 7.2) rather than assumed complete here.

2.4 Regulatory Context — RBI and NPCI

SOC 2 is a voluntary, contractually-driven attestation and does not substitute for, or overlap formally with, PaySafe India’s statutory obligations as an entity operating UPI rails governed by NPCI/RBI, and BNPL lending subject to the RBI’s digital lending guidelines. Those obligations run on a separate compliance track with their own audit cycles, reporting requirements, and regulator relationships, and are out of scope for this assessment. They are noted here only because two of the systems in scope for SOC 2 — the Payment Processing API (UPI routing) and the Settlement Reconciliation Module (BNPL and card settlement) — are the same systems subject to RBI oversight, so remediation work funded and scheduled for RBI/NPCI compliance reasons may also close SOC 2 gaps in this assessment, and PaySafe India’s Head of Compliance should confirm that the two workstreams are deconflicted rather than duplicated before the roadmap in Section 7 is finalized.

3. Control Mapping and Readiness Maturity Matrix

Readiness maturity is scored on a four-point scale — *Not Started* / *Designed, Not Yet Operating* / *Operating, Insufficient Evidence* / *Operating Effectively* — deliberately not RAG. RAG asks whether a control exists against a standard; this asks whether the control, as it stands today, would survive an auditor’s evidence request. A control can be well-designed and still rate below *Operating Effectively* if the only proof of it operating is a policy document rather than a log, a ticket, or a re-performed test — which is exactly the distinction that separates several rows below from where the ISO 27001 Gap Analysis or PCI DSS Gap Analysis would have rated the equivalent control.

Where a control already exists because of ISO 27001 or PCI DSS remediation work, that is noted rather than treated as new — SOC 2 frequently re-tests the same underlying control against a different, and often stricter, evidence bar (a quarterly access review satisfies ISO 27001's cadence requirement; SOC 2 wants to see that review actually happen and be signed for a full period under observation, which is a Type II question this assessment flags now so it does not surprise anyone in Section 6).

Criterion / Grouping	Points of Focus (illustrative)	Readiness Maturity	Rationale	Detailed Finding
CC1 — Control Environment	CC1.1–CC1.5	Operating, Insufficient Evidence	Governance structure, CISO accountability, and role definitions are documented and match how the organization actually runs. Security-awareness training, however, is running at 81% completion against a 95% target (Internal Audit Finding 06) — a CC1.4 competence point of focus with a real operating gap, not a paper one.	Gap 1, §4.1
CC2 — Communication and Information	CC2.1–CC2.3	Operating Effectively	Internal policy communication and the reporting lines used throughout the TPRM Framework and Internal Audit report demonstrate this criterion operating in practice, not just on paper — the RACI in TPRM Section 10 is itself evidence of it.	—
CC3 — Risk Assessment	CC3.1–CC3.4	Operating Effectively	The Risk Register actively drives testing depth and prioritization across two independent assessments (Internal Audit Appendix D, PCI DSS Section 3.0) — this is a risk-assessment process an auditor can trace being used, not merely maintained.	—

Criterion / Grouping	Points of Focus (illustrative)	Readiness Maturity	Rationale	Detailed Finding
CC4 — Monitoring Activities	CC4.1–CC4.2	Designed, Not Yet Operating	SIEM ingestion is in place across every in-scope system, but no correlation rules exist for anomalous cardholder-data access (PCI Finding 07), and High/Critical alert triage misses its own 1-hour SLA 40% of the time (Internal Audit Finding 03). Monitoring exists; monitoring that catches things does not, yet.	Gap 2, §4.2
CC5 — Control Activities	CC5.1–CC5.3	Operating, Insufficient Evidence	Control activities are designed and mapped consistently across the ISO 27001, PCI DSS, and TPRM deliverables, but a control-activities criterion is only as strong as its weakest operating instance, and CC5's evidence quality tracks CC6 through CC9 below.	—
CC6 — Logical and Physical Access Controls	CC6.1–CC6.8	Designed, Not Yet Operating	The single largest readiness gap in this assessment. MFA is not consistently enforced for privileged and third-party remote access (Internal Audit Finding 01, Critical; PCI Finding 06), and terminated-employee deprovisioning missed its 24-hour SLA by 400% in a sampled case (Internal Audit Finding 02, Critical). Physical access (CC6.4) is solid — PCI DSS Req 9 rated Green — but that does not offset	Gap 3, §4.3

Criterion / Grouping	Points of Focus (illustrative)	Readiness Maturity	Rationale	Detailed Finding
			the logical-access failures.	
CC7 — System Operations	CC7.1–CC7.5	Operating, Insufficient Evidence	Vulnerability management and incident-detection capability exist, but the same monitoring gaps under CC4 recur here, and configuration baseline drift on production payment-processing hosts (Internal Audit Finding 07) went unremediated with no linked change-control record for two of twelve sampled hosts.	Gap 2, §4.2
CC8 — Change Management	CC8.1	Operating, Insufficient Evidence	Change control exists and is referenced consistently across the ISO 27001 and PCI DSS deliverables, but SAST is not integrated into the admin portal's CI/CD pipeline (PCI Finding 04) and dependency scanning is ad hoc — meaning the change-management process itself is sound while one of its most consequential gates is missing.	Gap 4, §4.4
CC9 — Risk Mitigation	CC9.1–CC9.2	Operating, Insufficient Evidence	The TPRM Framework is a genuinely mature vendor-risk program — worked risk assessments, a fixed scoring matrix, tiered monitoring. But the Fourth-Party Concentration Register (TPRM Section 6) shows seven of eight	Gap 5, §4.5

Criterion / Grouping	Points of Focus (illustrative)	Readiness Maturity	Rationale	Detailed Finding
			vendors with fourth-party disclosure still pending, which is an evidence gap an auditor would sample directly into.	
A1 — Availability	A1.1–A1.3	Operating, Insufficient Evidence	A consolidated DR plan exists covering the UPI switch, core banking interface, and card-processing gateway, and Internal Audit observed one walkthrough test (Finding-adjacent, A.5.30 in Appendix A). One test in the audit period is evidence of the capability existing; it is not yet evidence of it operating reliably across a review period.	Gap 6, §4.6
C1 — Confidentiality	C1.1–C1.2	Designed, Not Yet Operating	The card vault's tokenization model is a strong confidentiality control operating exactly as designed. The settlement reconciliation module is not: unmasked PAN retained 180 days against a five-to-seven-day need (PCI Finding 03) is the readiness assessment's single most consequential open item, full stop.	Gap 7, §4.7
PI1 — Processing Integrity	PI1.1–PI1.5	Designed, Not Yet Operating	This is the criterion most fintechs at PaySafe India's stage under-resource, and PaySafe India is no exception. The closest thing to a processing-integrity control — settlement	Gap 8, §4.8

Criterion / Grouping	Points of Focus (illustrative)	Readiness Maturity	Rationale	Detailed Finding
			reconciliation — is the same process failing Confidentiality above, and no independent completeness/accuracy monitoring over transaction processing has been evidenced separately from that reconciliation job.	
P1–P3 — Privacy: Notice, Choice/Consent, Collection	P1.1–P3.2	Designed, Not Yet Operating	DPDP 2023 gives PaySafe India a real Data Fiduciary/Data Processor framework (TPRM Section 9), but it has not been mapped onto AICPA's privacy points of focus in a form an auditor would recognize as a control — the legal obligation exists; the SOC 2 control artifact built on top of it does not yet.	Gap 9, §4.9
P4–P8 — Privacy: Use/Retention, Access, Disclosure, Quality, Monitoring	P4.1–P8.1	Operating, Insufficient Evidence	Data Processing Agreements are the primary control artifact here, and two of eight TPRM-registered vendors — Sundial HR Payroll and BhashaConnect — still lack an executed DPA (TPRM Section 9.3), both processing personal data. Both are scheduled for the current renewal cycle, but "scheduled" is not "executed" at the point an auditor samples the vendor file.	Gap 9, §4.9

3.1 Sampling Basis

Sample sizes cited throughout Section 3 and Section 4 (e.g., three of eight sampled privileged accounts under CC6, two of twelve sampled hosts under CC7, one of five sampled separations under CC6) are inherited directly from the sampling performed in Internal Audit Report PSI-IA-2026-04 and PCI DSS Gap Analysis PSI-PCI-2026-01, not independently re-sampled for this assessment. Those source engagements applied attribute sampling against populations of the size described, consistent with the sample-size guidance an external auditor would apply for design and operating-effectiveness testing of similarly sized populations. This assessment relies on that sampling rather than duplicating it, on the basis that re-sampling the same population over the same period would not produce new evidentiary value. A SOC 2 examiner will independently draw its own sample rather than accept this assessment's — or Internal Audit's — sample as a substitute, and PaySafe India should expect sample composition, though not necessarily conclusions, to differ from what is cited here.

4. Detailed Readiness Gaps

Every gap write-up below corresponds to a criterion rated below *Operating Effectively* in Section 3. Where a gap is already documented in the ISO 27001 Gap Analysis, the Internal Audit report, or the PCI DSS Gap Analysis, this section states the SOC 2-specific evidence consequence rather than repeating the underlying finding in full.

Gap 1 — CC1.4: Security Awareness Training Below Completion Target

Evidence expectation vs. current state: An auditor sampling CC1.4 wants a training-completion report tied to a defined population and a phishing-simulation trend showing the control working over time, not a single snapshot. PaySafe India has the dashboard (Internal Audit Finding 06 confirms this), but at 81% completion against a 95% target and an 18% phishing click-through rate against a 10% target, the evidence itself shows the control under-performing its own stated tolerance — this is a case where producing the evidence is what creates the finding. **Readiness risk:** Noted exception in the report rather than examination-blocking on its own, but it compounds the CC6 access-control findings below: the same population failing awareness training overlaps meaningfully with the population an auditor will already be probing for credential hygiene.

Gap 2 — CC4/CC7: Monitoring Exists, Detection Does Not

Evidence expectation vs. current state: SOC 2 wants evidence that anomalous activity is detected and acted on within a defined timeframe — alert logs, triage tickets, mean-time-to-triage trending downward. PaySafe India's SIEM ingests logs from every in-scope system (a genuine asset), but zero correlation rules are tagged to cardholder-data access patterns (PCI Finding 07), and 40% of sampled High/Critical alerts missed the 1-hour triage SLA, two of them by more than 24 hours (Internal Audit Finding 03). Configuration drift compounds this: two of twelve sampled production hosts deviated from baseline with no linked change-control record (Internal Audit Finding 07). **Readiness risk:** Examination-blocking if unresolved. A detective control with a documented 40% SLA miss rate, sampled directly by an internal audit team using the same population an external auditor would draw from, is close to the worst evidence an examiner can be handed — it does not require them to find the gap themselves.

Ownership note: 24x7 log monitoring is operated by Kavach Managed Security Services under a managed detection and response arrangement (Section 2.2), not performed entirely in-house. Before this gap is assigned to an internal "SOC Lead," PaySafe India needs to determine whether the correlation-rule gap and the SLA-miss gap sit with Kavach's service delivery, with PaySafe India's own tuning and escalation process on top of Kavach's alerts, or both — and whether Kavach's own control

performance here needs to be addressed as a Complementary Subservice Organization Control per Section 5.1, rather than solely as an internal CC4/CC7 finding. The remediation roadmap in Section 7 is written on the assumption that this is a joint internal/vendor fix; that assumption should be confirmed with Kavach's account team before the roadmap dates are treated as fixed.

Gap 3 — CC6: Access Control Is Designed Correctly and Is Not Operating

Evidence expectation vs. current state: CC6 evidence is authentication logs, access-review sign-offs, and deprovisioning tickets traced against HR separation dates — exactly what Internal Audit already sampled. Three of eight sampled privileged accounts belonging to a third-party vendor authenticated to production VPN with a static password and no MFA challenge (Internal Audit Finding 01, Critical; independently corroborated by PCI Finding 06). Separately, one of five sampled employee separations showed Active Directory, VPN, and BNPL loan-origination access remaining live for five days against a 24-hour SLA (Internal Audit Finding 02, Critical). **Readiness risk:** Examination-blocking. Both findings are Critical-rated by an internal team using methodology an external auditor would recognize and likely replicate. Walking into an examination with these open is not a risk of a qualified opinion — it is close to a guaranteed one, and possibly a declined engagement if disclosed to the auditor in advance, which it should be.

Gap 4 — CC8: Change Management Is Sound, One Gate Is Missing

Evidence expectation vs. current state: An auditor wants to see a secure development lifecycle applied consistently across every in-scope codebase. The payment processing API has manual secure code review at each release; the admin portal — with direct query access to the transaction database — ships through CI/CD with no automated static-analysis gate, and dependency scanning happens only when a developer remembers to (PCI Finding 04). **Readiness risk:** Likely to produce a noted exception rather than block examination outright, since the underlying change-management process is otherwise well-evidenced, but the admin portal's direct data access makes this a harder gap to argue is immaterial than its narrow scope suggests.

Gap 5 — CC9.2: Fourth-Party Visibility Incomplete Across the Vendor Population

Evidence expectation vs. current state: CC9.2 wants evidence that vendor risk, including subcontractor risk, is actively monitored — not just that a register exists. The TPRM Framework's own Fourth-Party Concentration Register (Section 6) is candid about this: only Aegis's subcontractor exposure is substantiated; the remaining seven vendor rows are placeholders pending DDQ Section 4.5 responses. **Readiness risk:** Noted exception. The register's honesty about its own incompleteness is, perversely, a point in PaySafe India's favor with an auditor — a "clean" register with no acknowledged gaps would invite more scrutiny, not less — but it cannot be presented as closed evidence, and should not be.

Gap 6 — A1: Availability Testing Is a Single Data Point, Not a Trend

Evidence expectation vs. current state: Availability evidence an auditor samples for is capacity monitoring, incident postmortems tied to availability commitments, and DR test results across more than one cycle. PaySafe India has a current, consolidated DR plan and one observed walkthrough test in the audit period. **Readiness risk:** Acceptable for Type I, where a point-in-time design assessment is the standard; insufficient for Type II, where "operating effectively" needs to be shown across the observation window, not demonstrated once during fieldwork.

Gap 7 — C1: Unmasked PAN Retention Is the Assessment’s Headline Confidentiality Failure

Evidence expectation vs. current state: Confidentiality evidence is a data classification and retention schedule matched against actual system behavior. PaySafe India’s card vault matches its retention story; the settlement reconciliation module does not — 180 days of unmasked PAN retained against a five-to-seven-day reconciliation-plus-dispute window (PCI Finding 03), on a legacy retention schedule inherited from an unrelated general-ledger policy and never updated when the process was automated.

Readiness risk: Examination-blocking as currently designed. The PCI DSS Gap Analysis already proposes an interim compensating control (envelope encryption, retention cut to seven days, access alerting) pending the vendor’s Q1 2027 connector upgrade — that control, once implemented, is the difference between this gap blocking Type I and merely producing a qualified opinion. It should not be presented to a SOC 2 auditor as closed; it should be presented as an interim measure with a stated end date, exactly as the PCI report frames it.

Gap 8 — PI1: No Processing-Integrity Control Independent of the Broken Reconciliation Process

Evidence expectation vs. current state: PI1 evidence is a demonstrable check that transactions processed match transactions authorized — completeness and accuracy monitoring independent of any single downstream use of that data. PaySafe India’s only real candidate for this control is the settlement reconciliation module, which is simultaneously the subject of Gap 7. There is no separately evidenced processing-integrity control that would survive on its own if the reconciliation module’s confidentiality problem is fixed but its accuracy-checking function is not examined independently. **Readiness risk:** Examination-blocking for a Processing Integrity opinion specifically, though not for Security or Confidentiality in isolation. This is the clearest argument in this assessment for treating Processing Integrity as a category needing new control design, not remediation — there isn’t yet a control to remediate.

Gap 9 — Privacy (P1–P8): DPDP Compliance Is Not Yet a SOC 2 Privacy Control

Evidence expectation vs. current state: Privacy evidence maps to AICPA’s points of focus specifically — a privacy notice, a documented consent mechanism, a data-principal-rights fulfillment process with tracked SLAs, and executed Data Processing Agreements with every vendor touching personal data. PaySafe India has the legal foundation (DPDP Data Fiduciary/Processor structure, TPRM Section 9) but two of eight registered vendors — Sundial HR Payroll and BhashaConnect — still lack an executed DPA despite both processing personal data (TPRM Section 9.3), and no artifact in this portfolio yet maps DPDP obligations one-to-one onto the specific AICPA privacy points of focus an auditor tests against.

Readiness risk: Examination-blocking for a Privacy opinion. Acceptable to exclude Privacy from an initial Type I scope if PaySafe India’s banking-partner and enterprise-customer contracts do not yet demand it — but that is a scoping conversation to have deliberately, not a gap to discover during fieldwork.

5. Complementary User Entity Controls (CUECs)

SOC 2 assumes PaySafe India’s control environment works only if the entities relying on this report also operate certain controls themselves. These are not PaySafe India’s responsibility to execute, but they must be stated plainly enough to appear verbatim in the eventual report, because an auditor’s opinion is conditioned on them holding.

1. **Customer-side access provisioning to the Admin Portal.** Relying entities are responsible for granting, reviewing, and revoking their own personnel’s access credentials to PaySafe India’s admin

portal and merchant-facing dashboards in a timely manner consistent with their own internal access-control policies.

2. **Safeguarding of API credentials and integration secrets.** Relying entities are responsible for the secure storage, rotation, and restricted distribution of API keys, webhook secrets, and integration credentials issued by PaySafe India; PaySafe India's controls do not extend to credential hygiene inside a customer's own environment.
3. **Timely notification of authorized-user changes.** Relying entities are responsible for promptly notifying PaySafe India when personnel with access to PaySafe India systems change roles or leave the relying entity's employment, so that PaySafe India's own deprovisioning workflow (Section 3, CC6) can act on accurate information.
4. **Accuracy of data submitted for KYC and onboarding.** Relying entities and their end customers are responsible for the accuracy and completeness of identity and account information submitted through onboarding flows; PaySafe India's KYC controls (operated in part through Nirmaan KYC Solutions) verify what is submitted but cannot independently correct for what a relying entity supplies incorrectly.
5. **Review of transaction and settlement reports.** Relying entities are responsible for reviewing settlement and reconciliation reports provided by PaySafe India on a timely basis and promptly reporting discrepancies, consistent with the reconciliation cycle described in Section 2.2.
6. **Configuration of relying-entity-side security controls for integrations.** Where a relying entity connects to PaySafe India via API, the relying entity is responsible for its own transport-layer security configuration, IP allow-listing, and secret management on its end of the integration.

5.1 Complementary Subservice Organization Controls (CSOCs)

CUECs address what relying entities owe PaySafe India. A separate and equally necessary question — not yet decided anywhere in this assessment's source portfolio — is what PaySafe India's own report will owe to controls performed by its subservice organizations, and whether those organizations are addressed using the **inclusive method** (their controls are examined and included directly in PaySafe India's report) or the **carve-out method** (their controls are excluded, and PaySafe India's report instead lists the complementary controls it is relying on those organizations to perform). Per AT-C 205.20–.21 and the AICPA SOC 2 Guide, this decision must be made and disclosed per subservice organization, not defaulted to one method across the board:

7. **Aegis Cloud Systems (IaaS/PaaS hosting for the UPI switch, card-processing environment, and core-banking interface).** Given the scale of this dependency — Section 2.2 already names it a Critical-tier vendor — the carve-out method is the more realistic path, which means PaySafe India's eventual report will need explicit CSOC language covering physical and environmental security, host-level patching, and hypervisor-layer access controls that Aegis performs and PaySafe India does not independently test.
8. **Aster Payment Gateway Solutions (card, UPI, and net-banking transaction processing).** Aster already holds its own current SOC 2 Type II attestation (Section 2.2). This is the more favorable case: PaySafe India can obtain and reference Aster's own report (with a bridge letter covering any gap between Aster's report period and PaySafe India's) rather than needing to draft original CSOC language, but this substitution needs to be documented as a deliberate reliance decision, not assumed.

9. **Kavach Managed Security Services (24x7 monitoring over production logs, MDR).** This is the most consequential open question. Kavach's monitoring function is the same control this assessment already scores as failing under CC4/CC7 (Gap 2). If Kavach is carved out, the correlation-rule and SLA-triage gaps described in Gap 2 may belong partly or entirely to Kavach's own control environment rather than PaySafe India's, which changes who owns remediation and what evidence PaySafe India can reasonably produce directly. This should be resolved before the Section 7 roadmap dates for Gap 2 are treated as commitments.
10. **Vahini Communication Services, Nirmaan KYC Solutions, Praxis Fraud Analytics.** Lower-materiality relative to the criteria in scope, but each touches an in-scope process (transaction authentication, onboarding, fraud risk-scoring respectively) and should receive at minimum a documented inclusive/carve-out decision, even if the answer is "immaterial to this examination's scope."

No CSOC language exists anywhere in this assessment's source portfolio today. Drafting it is added to the remediation roadmap (Section 7.2).

6. Type I vs. Type II Readiness Decision

Recommendation: pursue Type I, not now, but once the Immediate-horizon remediation in Section 7 closes — realistically Q4 2026 — and defer Type II until a minimum six-month clean observation window can start after that, no earlier than mid-2027.

The case against pursuing Type I immediately is not close. Type I only requires that controls be suitably designed and implemented as of a point in time, and even that lower bar is not met while two Internal-Audit-rated Critical findings sit open against target dates of 15 and 31 August 2026, and while the Confidentiality gap in Section 4 (unmasked PAN retention) has no committed fix faster than a third-party vendor's Q1 2027 release. An examiner performing even a design-level walkthrough during the current fieldwork window would find controls that are documented but demonstrably not implemented as described — that is a Type I failure, not a Type II one, because Type I doesn't test whether a control operated over time; it tests whether the control that exists on paper is the control that actually exists.

The case for Type I once remediation lands, rather than waiting for Type II readiness before engaging at all, is about sequencing incentive and cost. Type I gives PaySafe India's banking partners and enterprise customers a credible, examiner-issued signal months before a Type II report could possibly be ready, and it forces the organization to close the Immediate-horizon items in Section 7 against an external date rather than an internal one — which, given that two of those items have already slipped past a prior internal remediation commitment once (the Internal Audit findings themselves), is a meaningful forcing function on its own.

The case against jumping straight to Type II is the genuine trade-off here, and it deserves to be stated honestly rather than assumed. Type II is the report banking partners actually prefer — it demonstrates operating effectiveness over time rather than a snapshot, and several of PaySafe India's own vendors (Aster Payment Gateway Solutions, per TPRM Section 5.2) already hold Type II reports that PaySafe India relies on directly. Pursuing Type I first costs time: an interim Type I report, then a six-to-twelve-month Type II observation window, then the Type II examination itself, pushes a Type II report out to roughly mid-to-late 2027 versus a hypothetical (and currently unachievable) direct Type II pursuit. That delay is the real cost of this recommendation, and leadership should understand it as a deliberate trade rather than a default.

The observation-window clock for Type II should not start until three conditions are true, not just the passage of calendar time: (1) both Critical Internal Audit findings are independently re-tested and confirmed closed, not just self-reported as remediated by the owning teams — Internal Audit’s own report already recommends this re-test; (2) the settlement reconciliation compensating control from the PCI DSS Gap Analysis (envelope encryption, seven-day retention, access alerting) is live and has itself been observed operating for at least one full reconciliation cycle, since a Type II window cannot begin against a control that is itself brand new; and (3) PaySafe India has made an explicit scoping decision on whether Processing Integrity and Privacy are included in the first Type II cycle, given that Gap 8 and Gap 9 in Section 4 describe categories needing new control design, not remediation of existing controls — a Type II window cannot observe a control operating effectively if the control did not yet exist for most of the window.

7. Remediation Roadmap

Every gap from Section 4 is prioritized below into three horizons. Where a gap traces to an existing ISO 27001, PCI DSS, or TPRM remediation item already owned elsewhere in PaySafe India’s governance structure, this roadmap references that ownership rather than duplicating it — the point of this roadmap is to state what has to be true for SOC 2 readiness specifically, not to re-litigate work already scheduled.

7.1 Immediate (0–30 days) — Examination-Blocking Gaps

Item	Owner Role	Effort	Dependency Notes
Close Gap 3 — MFA enforcement for privileged and third-party remote access	Head of IT Security	Already scheduled; Internal Audit target 15 August 2026	This roadmap does not add new work — it flags that SOC 2 readiness cannot proceed past this horizon until Internal Audit’s own target date is met and independently re-tested, not merely self-declared closed.
Close Gap 3 — Deprovisioning SLA automation	IT Operations Manager	Already scheduled; Internal Audit target 31 August 2026	Same dependency structure as above; automation of the HR-to-IT trigger is the actual fix, not faster manual follow-up.
Implement Gap 7 interim compensating control — settlement export encryption and retention cut	Head of Settlement Operations, with CISO sign-off	~₹4–6 lakh; 2 engineer-weeks (per PCI DSS Gap Analysis Section 6.1)	Must be observed operating for at least one full reconciliation cycle before it can support even a Type I design assertion for C1 and PI1.

Item	Owner Role	Effort	Dependency Notes
Independent re-test of both Critical findings once self-declared closed	Internal Audit function	1 engineer-week equivalent	Internal Audit's own report already recommends this; SOC 2 readiness treats the re-test, not the closure declaration, as the evidence event.

7.2 Short-term (30–90 days) — Gaps That Would Produce a Qualified Opinion or Noted Exception

Item	Owner Role	Effort	Dependency Notes
Close Gap 2 — SIEM correlation rules for cardholder-data access patterns	SOC Lead, with Detection Engineering, pending confirmation of Kavach's role per Section 5.1	~₹8–10 lakh; 3–4 engineer-weeks (cost basis per PCI DSS Gap Analysis — citation to be confirmed ; this figure was previously cross-referenced to Section 6.1, the same subsection cited for the unrelated settlement-encryption fix above, which is likely a copy-paste artifact rather than the correct subsection)	Directly closes both the CC4 and CC7 rows in the maturity matrix; no new procurement required, subject to the Kavach ownership question in Section 5.1.
Close Gap 2 — 24x7 SIEM alert triage coverage	Head of IT Security	Effort per Internal Audit Finding 03 remediation, target 30 September 2026	Either additional headcount or MDR expansion via Kavach Managed Security Services (TPRM register); either path closes the same evidence gap.
Close Gap 4 — SAST integration into admin portal CI/CD	Engineering Lead, Admin Portal	~₹5–7 lakh; 3 engineer-weeks (per PCI DSS Gap Analysis Section 6.3)	No external blocker once CI/CD tooling budget clears.
Close Gap 5 — Complete fourth-party disclosure across remaining seven TPRM vendors	Third-Party Risk Manager	Effort scales with vendor cooperation; DDQ Section 4.5 re-issue already scheduled per TPRM Framework	A vendor unable to answer within one re-issue cycle is itself escalated per TPRM Section 1.2 — that escalation path is the evidence an auditor

Item	Owner Role	Effort	Dependency Notes
			wants to see used, not just documented.
Draft the DPDP-to-AICPA privacy points-of-focus mapping (Gap 9)	Head of Compliance, with Data Protection Officer	2–3 person-weeks	This is net-new control design, not remediation — treat it as a deliverable in its own right rather than folding it into existing DPDP workstreams.
Decide inclusive vs. carve-out treatment for Aegis, Aster, and Kavach, and draft CSOC language for any carved-out relationship (Section 5.1)	Head of Compliance, with Third-Party Risk Manager and CISO sign-off	2 person-weeks plus vendor coordination time; Aster likely resolved fastest via bridge-letter reliance on its existing SOC 2 Type II report	Must be resolved before Gap 2's roadmap dates (above) are treated as fixed, since Kavach's carve-out status determines who owns that gap's remediation.
Benchmark the System Description (Section 2.2) against the AICPA Description Criteria (Section 2.3) and remediate any gaps found	Head of Compliance, with Lead Readiness Advisor	1–2 person-weeks	Should be completed before the description is finalized for inclusion in the eventual auditor's report package.
Confirm RBI/NPCI compliance workstreams for the Payment Processing API and Settlement Reconciliation Module are deconflicted, not duplicated, against this roadmap (Section 2.4)	Head of Compliance	1 person-week	Administrative reconciliation, not new control work — avoids double-funding the same fix under two compliance programs.

7.3 Medium-term (90–180 days) — Acceptable for Type I but Must Close Before a Type II Window Can Start

Item	Owner Role	Effort	Dependency Notes
Execute outstanding DPAs — Sundial HR Payroll and BhashaConnect (Gap 9)	Legal, with Third-Party Risk Manager	Per TPRM Framework Section 9.3, current renewal-cycle target	Acceptable open item for a Type I design assertion if scoped honestly; not acceptable for a Type II observation window covering Privacy.

Item	Owner Role	Effort	Dependency Notes
Design an independent Processing Integrity control separate from settlement reconciliation (Gap 8)	Head of Engineering, with Head of Settlement Operations	New control design; scope and effort TBD pending design decision	This is the roadmap's largest open question. PaySafe India should decide in this horizon whether Processing Integrity is in scope for the first Type I/Type II cycle at all, rather than defaulting to full scope by inertia.
Second DR test cycle to establish an availability trend, not a single data point (Gap 6)	Head of Engineering (Infrastructure)	1 additional test cycle	Directly supports the Section 6 condition that a Type II observation window needs more than one demonstrated instance of the control operating.
Bring vendor-default remote-root access on legacy database replicas fully into scope (supports CC6, tracked jointly with PCI Finding 02)	Database Platform Owner, with the Third-Party Risk Manager	Cost basis per PCI DSS Gap Analysis — citation to be confirmed ; this figure was previously cross-referenced to Section 6.3, the same subsection cited for the unrelated admin-portal SAST fix above, which is likely a copy-paste artifact rather than the correct subsection; ~₹10–15 lakh	Not independently listed as a Section 4 gap here because it is already tracked under PCI DSS Finding 02, but it touches CC6 evidence directly and should be confirmed closed before Type II fieldwork on access controls begins.

This assessment should be read alongside the ISO/IEC 27001:2022 Gap Analysis (v1.0), the Third-Party Risk Management Framework (v1.0, PSI-TPRM-2026-01), the PCI DSS v4.0 Gap Analysis (v1.0, PSI-PCI-2026-01), and the Internal Audit Report (PSI-IA-2026-04). Where a finding in this document restates a finding from one of those four, the restatement is deliberate — the point of a SOC 2 readiness assessment is to say what the same underlying control gap means against a different evidence bar, not to discover new gaps in isolation.

— End of Assessment —